



AI 보안 교육(기초)

보안 등급: 훈련센터 내 활용

국가·공공기관 AI 보안 교육

안전한 활용을 위한 가이드 및 대응 방안

**교육 대상**

30명 국가·공공기관 담당자
오프라인 집체교육

**교육 형태**

집체교육 **2일**
실습 중심 진행

**교육 일정**

2026년 7월(예시)
오프라인 교육 진행



국가·공공기관 담당자



실무 AI 활용



보안 인식 강화

사이버안보훈련센터(CSTEC)

양경아 책임연구원

2026년 6월

 목차

| 교육 구성 (총 6개 섹션)

최근 AI 활용 동향



생성형 AI부터 에이전트 AI까지의 진화, 공공부문 AI 활용 현황과 트렌드 분석

AI 동향

공공부문

위험 시나리오와 OWASP LLM Top 10



실제 위험 시나리오와 OWASP LLM Top 10 기반 보안 위협 체계 분석

보안 위협

위험 시나리오

기관 적용 운영모델



정보화 7명·보안 1명 조직에 맞춘 AI 운영 모델과 Do/Don't 체크리스트

운영 모델

체크리스트

국가·공공기관 활용 현황



해외(영국, 싱가포르, 미국)와 국내 공공기관의 AI 활용 사례 분석

해외 사례

국내 사례

안전한 사용·구축·바이브 코딩 가이드



안전한 AI 사용 원칙, 구축 방안, 바이브 코딩 가이드 및 체크리스트

안전 가이드

바이브 코딩

참고자료 및 부록



국내외 공공기관 AI 우수 사례, 피해 사례, 안전한 AI 사용 자료

참고자료

부록

 대상: **30명** 국가/공공기관 사이버보안 담당자



AI 교육 필요성 - 국정원 AI 위험사례집 기반

AI 위험 시나리오 분류 체계

국정원 AI 위험사례집 (2025.11) - 총 70건 시나리오

최신

18

국가안보

17

재난·인프라

17

경제·산업·의료

18

사회·민생·인권



공공부문 AI 도입 가속화

정부·공공기관에서 AI를 활용한 업무 자동화가 확대되고 있으나, 보안·프라이버시 리스크가 함께 증가하고 있습니다.



최신 가이드 정비 현황

PIPC 생성형 AI 개인정보 처리 안내서(2025.8), UK AI Playbook(2025.2), KISA AI 보안 안내서, 국정원 AI 위험사례집(2025.11) 등 정비 완료

! 주요 위험 요소

AI 시스템은 △내부 작동의 불투명성 △데이터 편향 등 자체적 한계에 더해 △보안 체계 미흡 △윤리 기준 미비 등 다양한 문제점을 안고 있습니다.

위험 분야별 시나리오



국가안보 분야

18건

- ✓ 자율무기 로봇 오류로 아군 공격
- ✓ 자율감시 드론 영공 무단 침입
- ✓ 군사정보 AI 편향적 정보 생성



재난·인프라 분야

17건

- ✓ AI 에이전트 실수로 신규 바이러스 생성
- ✓ 자율주행 교통시스템 오류로 대규모 사고



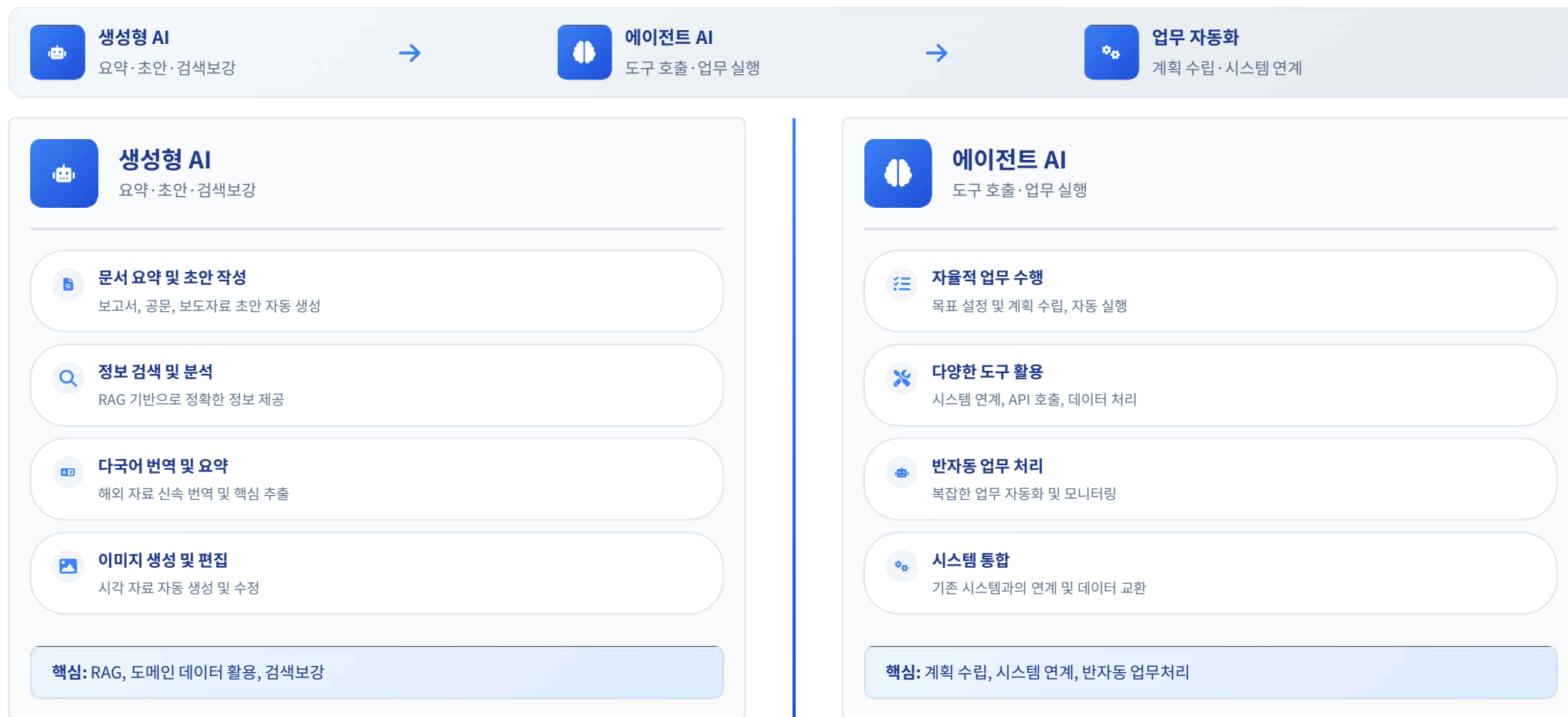
경제·산업·의료

17건

- ✓ AI 빅테크 서비스 일시 장애
- ✓ 의료 AI 영상 판독 정확도 상이

AI 활용의 진화

생성형 AI → 에이전트 AI → 업무 자동화로의 전환





공공부문 AI 최신 동향

5대 분야 AI 활용 트렌드

출처: NIA 공공분야 생성형 AI 활용 방안(2025년 1분기 기준)



행정 분야 핵심

보고서·공문 초안 작성, 규정 검색, 회의록 요약 등 업무 효율화
→ 민원 처리 시간 30% 단축 예상

문서 자동화

규정 검색

회의록 요약



민원 분야 확대

콜센터·챗봇 고도화, 다국어 안내, 자동 분류·라우팅
→ 월 3만 건 처리 (싱가포르 사례)

AI 챗봇

다국어 지원

자동 분류



보건복지 핵심

사례관리 요약, 대상자 분류, 돌봄 위험 신호 탐지
→ 복지 서비스 선제적 제공

사례관리

대상자 분류

위험 탐지



공공의료 신규

영상 판독 보조, 임상 문서 요약, AI 진단보조
→ 진단 정확도 15% 향상

영상 판독

임상 문서

AI 진단



인프라/보안 필수

폐쇄형/온프레미스 환경 구축, 데이터 거버넌스, DPIA 강화 → 개인정보 보호 및 보안 규정 준수

폐쇄형 환경

데이터 거버넌스

DPIA

보안 감사



해외 사례(1): 해외/국내 공공기관 AI 활용 사례

공공부문 AI 활용 우수 사례



영국

UK AI Playbook



프로젝트명

AI Playbook for UK Government



주요 내용

10대 원칙: 합법·윤리·보안·HITL·수명주기·거버넌스



핵심 성과

정부 부처별 AI 활용 표준화 및 안전성 확보

2025년 발표

상세 보기 →



싱가포르

GovTech AI



프로젝트명

One Service Chatbot



주요 내용

월 3만 건 처리, 자동 분류/라우팅, 2천 시간 절약



핵심 성과

민원 처리 시간 2일 단축, 업무 효율성 85% 향상

2021년 운영

상세 보기 →



미국

Federal AI Strategy



프로젝트명

AI.gov & NIST AI RMF



주요 내용

연방 기관 AI 표준화, 보안 권고, 위험 기반 평가



핵심 성과

AI 거버넌스 보드 구축, 라이브 인벤토리 관리

2024년 발표

상세 보기 →



해외 사례(2): 미국 연방정부 AI 전략

미국 연방정부 AI 전략 및 보안 체계

미국은 AI.gov를 통해 표준화된 AI 도입 가이드라인을 제공하고, NSA AISC를 중심으로 에이전트형 AI 보안을 강화하고 있습니다.



AI.gov 표준·가이드

운영 중

연방 기관 전반에 걸쳐 AI 도입을 위한 **표준화된 가이드라인**을 제공합니다. **NIST AI RMF** 적용을 통해 AI 시스템의 **위험 관리**와 **보안 평가**를 체계적으로 수행합니다.

- **AI.gov 플랫폼:** 연방 기관 AI 도입 표준 및 가이드라인 제공
- **NIST AI RMF:** AI 위험 관리 프레임워크 적용
- **보안 평가:** AI 시스템 보안성 평가 및 인증



조달·거버넌스 관리 체계

완료

AI 거버넌스 보드를 구성하여 **전략적 방향성**, **리스크 관리**, **규정 준수** 등을 감독합니다.

- **거버넌스 보드:** AI 전략 및 정책 결정
- **라이브 인벤토리:** AI 사용 현황 관리
- **조달 관리:** AI 솔루션 조달 프로세스



NSA AISC 에이전트 보안 권고

주의 필요

NSA AISC는 **에이전트형 AI**의 보안 위협을 분석하고, **단계적 도입**과 **위험기반 평가**를 권고

- **에이전트 보안:** 자율적 AI 시스템 보안 강화
- **단계적 도입:** 위험 평가 후 점진적 적용
- **지속적 모니터링:** AI 시스템 실시간 감시

핵심 시사점

미국 연방정부는 AI.gov를 통해 **표준화된 AI 도입**을 추진

NSA AISC를 통해 **에이전트형 AI 보안**을 강화

거버넌스 보드와 **라이브 인벤토리**로 AI 사용을 체계적으로 관리.



국내 사례(1): 보건복지부 AI 복지·돌봄 혁신

보건복지부 AI 복지·돌봄 혁신 TF 운영 현황

복지·돌봄 혁신 TF 운영 2024.8.8 발족

AI 복지·돌봄 혁신 추진단(TF)을 구성하여 복지·돌봄 분야의 근본적 혁신 방안을 논의하고, 향후 5년간 추진할 핵심과제들을 체계적으로 준비 중입니다.

- 단장: 이스란 제1차관
- 목표: 행정업무 부담 경감, 선제·통합 서비스 제공
- 계획: 상반기 혁신계획(26-30) 발표 예정

복지빅데이터 안전 활용 운영중

복지빅데이터의 안전한 활용 기반 마련을 통해, 데이터와 AI 기술이 제도와 사람을 연결하고 선제적이고 통합적인 복지서비스를 제공합니다.

- 데이터 가명화·암호화 처리
- 접근 권한 관리 및 감사 로그
- 개인정보 보호 조치 강화

행정 지원 에이전트 도입 준비중

복지행정 지원 체계(에이전트) 도입·확산 방안을 포함하여, 현장 공무원들의 소모적인 행정 업무를 줄여줄 지원 체계를 마련하고 있습니다.

- 보고서·공문 초안 자동 생성
- 민원 응대·안내 서비스 고도화
- 데이터 분석 및 정책 시사점 도출

윤리·거버넌스 확립 진행중

AI 윤리를 확립하고 민·관·학 등 다부문이 협력해 빠른 기술변화에 유연하게 대응하는 적응적 거버넌스를 구축합니다.

- AI 윤리 가이드라인 수립
- 다부문 협력 체계 구축
- 현장 종사자 역량 강화

복지·돌봄 AI 혁신은 행정 업무 자동화, 데이터 기반 정책 결정, 국민 체감 서비스의 3가지 축으로 추진되며, 2026년 상반기에 AI 복지·돌봄 혁신 로드맵을 발표할 예정



국내 사례(2): 국내 공공의료·지자체 AI 활용 사례

국내 공공부문 AI 활용 우수 사례



KR 경기도

AI 공공의료원



프로젝트명

AI 중심 공공의료원 조성 사업



주요 내용

AI 진단보조시스템 도입, 영상진단 자동화, 의료 데이터 AI 활용



핵심 성과

영상진단 정확도 95% 이상, 진단 시간 50% 단축

2026년 상반기

[상세 보기](#) →

KR 전국

공공 챗봇



프로젝트명

정부24 AI 챗봇 서비스



주요 내용

민원 응대·규정 안내, 도메인 지식 기반 답변, 다국어 지원



핵심 성과

민원 응대 시간 70% 단축, 만족도 85% 이상

2025년 운영

[상세 보기](#) →

KR NIA

생성형 AI 활용



프로젝트명

공공분야 생성형 AI 활용 방안



주요 내용

폐쇄형/온프레미스 환경, K-데이터 정비, 보안 강화



핵심 성과

업무 효율성 40% 향상, 데이터 유출 리스크 0%

2025년 발표

[상세 보기](#) →



국내 사례(2): 국내 공공의료·지자체 AI 활용 사례

국내 공공부문 AI 활용 우수 사례

AI 정부 서비스 사례집

막막한 AI 기획의 첫 단추를 채워줄 현장 중심 사례 이야기



행정안전부 NIA 한국지능정보사회진흥원
Korea Information Society Security Agency

CONTENTS

환경일반

사각지대 없는 홍수 안전망, AI가 완성하다
기후에너지환경부, AI 홍수 예보시스템
스스로 운영하는 정수장, 24시간 끊임 없는 물 안전망
기후에너지환경부, AI 기반 스마트 정수장

고용노동

반복 업무 분석은 AI가, 최종 판단은 담당자가
고용노동부(근로복지공단), AI 기반 산재조사 분류 모델
당신의 권리를 지키는 '연중무휴' AI 근로감독관
고용노동부, 근로감독관 AI 지원시스템

사회복지일반

위기 속 희망을 건네는 문자 한 통
보건복지부, 복지위기가구 발굴 AI 초기상담
외로움을 줄이고安心은 더한 AI 돌봄 서비스
경기도, 맞춤형 360° AI+돌봄 서비스

공공질서및안전

국민 안전을 위한 스마트 게이트
국토교통부(한국교통안전공단), AI 운전자적화인식시스템
디지털 치안을 책임지는 AI 수사관
행정안전부(국립과학수사연구원), 딥페이크 불법 콘텐츠 탐지 분석 모델

087

099

AI 활용 사례

AI국가전략	AI활용사례	AI전문자료	
 디지털 집현전 전 국민 지식 플랫폼 국가지식정보 통합플랫폼(디지털집현전)	 민원상담 AI 어시스턴트 서비스	 자율작업트랙터 시스템	 지능형 배리어프리 키오스크 서비스
 RPA 활용 영역이행 민원 행정 서비스	 AI 기술활용 수질 정화 로봇 예코로봇	 AI 기반 광고창작 지원 서비스	 에너지바우처 사각지대 해소 지원 서비스



공공기관 실무자 기대효과

AI 활용으로 업무 효율화와 서비스 혁신



문서 작성·요약, 기획업무 생산성 ↑

복잡한 보고서 작성 및 기획 업무 등 AI가 자동으로 수행하여 업무 시간 50% 절감



다학제 협업 협업 ↑

부서 간 정보 공유와 협업을 AI로 지원



대상자 분류 정확도 ↑

서비스 대상자를 AI가 자동 분류하여 맞춤형 서비스 제공 가능



문서 작성 표준화 품질 ↑

문서 작성 및 기록을 AI가 표준화하여 품질 편차 축소



업무 지식 검색 속도 ↑

내부 규정과 정책 자료를 AI로 빠르게 검색하여 업무 지식 즉시 확인

⚠ 주의사항

환각(Hallucination): AI 생성 내용은 반드시 사람 검토(HITL) 필요

편향성: AI 학습 데이터의 편향으로 인한 불공정 서비스 가능성

책임소재: AI 판단에 대한 최종 책임은 사람에게 있음

★ 기대효과

- ✓ 업무 시간 30~50% 절감 - 문서 작성 및 검색 시간 단축
- ✓ 서비스 품질 향상 - 정확한 대상자 분류 및 맞춤 서비스
- ✓ 다학제 협업 지원 - 전문 지식·민원·행정 연계 강화

실제 위험 시나리오(1) - 데이터 유출·망분리

국정원 AI 위험사례집 기반 데이터 유출·망분리 위험 분석

내부 기밀 유출

정부기관 보고서 생성용 AI

국정원 사례#6

높음



위험 설명

정부기관 보고서 생성용 AI, 데이터관리 실수로 민감정보 유출



영향도



90%



발생 가능성



85%



개인정보 유출

호주 NSW주 3,000명 피해

2025.10

높음



위험 설명

호주 뉴사우스웨일주 재건축 기관이 홍수 피해자 3,000명의 개인정보를 ChatGPT에 업로드



영향도



95%



발생 가능성



80%



외부 클라우드 저장

기관 자료 외부 업로드

국정원 사례#47

중간



위험 설명

외부망 PC 또는 클라우드에 개인정보·업무자료 저장 후 AI 활용



영향도



70%



발생 가능성



60%



검증되지 않은 코드

GitHub 기능 사용

GitHub Copilot

중간



위험 설명

AI 바이브 코딩으로 검증되지 않은 GitHub 기능 활용 시 취약점 노출



영향도



75%



발생 가능성



65%



실제 위험 시나리오(2)

GitHub·바이브 코딩·에이전트 위험 시나리오 분석 국정원 사례집 기반



검증되지 않은 코드

GitHub 기능 사용

높음



위험 설명

검증되지 않은 GitHub 코드/확장 기능 사용 → 악성 의존성·라이선스 이슈

✓ 오픈소스 라이브러리 사용 시 소스 코드 직접 검토 또는 보안 문제 검증



영향도



바이브 코딩 취약점

자동 커밋·PR 남용

높음



위험 설명

AI 바이브 코딩의 자동 커밋·PR 남용 → 취약 코드·비밀키 노출

✓ 자동 워크플로 금지, PR은 항상 사람 리뷰 필수



영향도



실제 위험 시나리오(2)

GitHub·바이브 코딩·에이전트 위험 시나리오 분석 국정원 사례집 기반



에이전트 권한 과다

Copilot 과권한

중간



위험 설명

Copilot 에이전트 권한 과다, 프롬프트 인젝션 유도, 워크플로 자동 실행 위험

✓ 트리거 권한 제한(write access만), 전용 브랜치 사용



영향도



프롬프트 인젝션

악성 입력 공격

중간



위험 설명

숨겨진 메시지로 프롬프트 인젝션 공격, AI 시스템 제어권 탈취

✓ 입력 검증 및 필터링, 피드백 데이터 무결성 확인



영향도





OWASP LLM Top 10 기반 AI 보안 위험 체계

공공기관 관점 OWASP LLM Top 10 위험 분석

OWASP LLM Top 10 (2025)

공공기관 AI 시스템에 특화된 위험 분석



LLM01: 프롬프트 인젝션

#01 ● 높음

공공기관 위험: 악의적인 입력으로 AI 모델 조작, 내부 문서 유출, 권한 우회 가능
대응: 입력 검증, 프롬프트 필터링, HITL 검증



LLM03: 학습 데이터 오염

#03 ● 중간

공공기관 위험: 훈련 데이터 조작으로 잘못된 정책 결정, 편향된 서비스
대응: 데이터 출처 검증, 정기적 감사, 품질 모니터링



LLM05: 공급망 취약점

#05 ● 높음

공공기관 위험: 타사 라이브러리, 플러그인, 데이터셋의 보안 취약점
대응: SBOM 관리, 의존성 검증, 정기적 보안 업데이트



LLM07: 불안정한 플러그인

#07 ● 중간

공공기관 위험: 검증되지 않은 플러그인, 확장 기능의 보안 취약점
대응: 플러그인 승인 프로세스, 정기적 보안 감사



LLM02: 불안정한 출력 처리

#02 ● 높음

공공기관 위험: AI 출력 검증 없이 시스템 실행, 악성코드 주입, XSS 공격
대응: 출력 검증, 샌드박스 환경, 보안 검사



LLM04: 모델 서비스 거부

#04 ● 중간

공공기관 위험: 과도한 요청으로 서비스 중단, 민원 처리 지연
대응: 요청 제한, 로드 밸런싱, 자동 확장



LLM06: 민감정보 노출

#06 ● 높음

공공기관 위험: 개인정보, 기밀문서, 군사정보 등 민감 데이터 유출
대응: 데이터 분류, 암호화, 접근 통제, DLP 적용



LLM08: 과도한 자율성

#08 ● 높음

공공기관 위험: AI 시스템의 비인가 행동, 자동화된 위험 결정
대응: 인간 통제(HITL), 권한 제한, 감사 로그

▲ 높은 위험: 5개 항목

! 중간 위험: 3개 항목

✓ 낮은 위험: 2개 항목



AI 보안 피해 · 경고 사례

국정원 AI 위험사례집 기반 실제 사고 사례

주의: 국정원이 발간한 AI 위험사례집(2025.11)의 70건 시나리오 중 **공공기관 관련 6건**을 분석하여 유사한 사고 예방을 위한 교훈을 얻어야 합니다.



호주 NSW주 개인정보 유출 해외 | 2025.10

호주 뉴사우스웨일주 재건축 담당 기관 계약자가 **홍수 피해자 약 3,000명**의 개인정보를 **ChatGPT 등 공개 AI 틀에 업로드**한 사건.

개인정보유출

ChatGPT



이스라엘 방공시스템 실패 해외 | 2025.6

이스라엘 방위군 AI 방공시스템, **하이파(Haifa) 지역**에 발사된 이란 미사일 **요격 실패**. 레이더 오작동으로 인한 판단 오류.

미사일요격실패

레이더오작동



미국 드론 민간인 오인 사살 해외 | 2024.5

미국 국방부, 시리아 북서부 대상 드론 공습 당시 **민간인을 알카에다 지도자로 오인**해 사살한 사실 시인.

민간인사살

오인사격



대만군 중국 드론 격추 해외 | 2022.9

대만군, 중국이 동중국해·타이완해협 일대 군사 활동을 늘리며 **'드론 회색지대 전술'** 펼칠 때 진먼 군도 해안에서 정체 미상 드론 격추.

드론격추

회색지대전술



리비아 자율무기 공격 해외 | 2021.2

UN 리비아 전문가 패널, 보고서 S/2021/229를 통해 **STM Kargu-2**와 무인전투기 등이 보급 차량 행렬과 퇴각 부대 공격.

자율무기

무인공격



국내 공무원 기밀 유출 국내 | 2024년

보건소 직원이 민감한 **내부 문서**를 ChatGPT에 직접 입력하여 **기밀 유출** 사고 발생.

기밀유출

공무원

! 사고 유형: **6건** 분석 완료

🌐 국내: **1건** | 해외: **5건**

📅 기간: **2021-2025년**



안전한 AI 사용 원칙

실무자를 위한 5가지 핵심 원칙 체크리스트

KISA AI 보안 안내서(과학기술정보통신부·한국인터넷진흥원) 기반



1. 데이터 분류



- ✓ 대외비/PII는 외부망 LLM에 입력 금지 **필수**
- ✓ 가명·마스킹 후 최소 공유
- ✓ 데이터 등급에 따른 접근 제어

출처: KISA AI 보안 안내서 2.3.1



2. 망분리 준수



- ✓ 내부망은 폐쇄형 도구만 사용 **필수**
- ✓ 교차 전송은 승인·기록 필수
- ✓ 물리적 분리 환경 유지

출처: KISA AI 보안 안내서 2.1.1



3. 승인 도구 사용



- ✓ 공인 포털·게이트웨이로 접속 **필수**
- ✓ 프롬프트·출력 로그 보관
- ✓ 검증된 도구만 사용

출처: KISA AI 보안 안내서 3.4.1



4. 최소권한·HITL



- ✓ 자동결정 금지, 사람 검토 필수 **필수**
- ✓ 접근 권한 최소화
- ✓ 결재 프로세스 준수

출처: KISA AI 보안 안내서 4.2.4



5. DPIA·투명성



- ✓ 처리 목적·근거 명시 **필수**
- ✓ 접근권 관리
- ✓ 감사 로그 유지

출처: KISA AI 보안 안내서 1.2.2



6. 인적 검토



- ✓ HITL 원칙 준수 **필수**
- ✓ 사실 검증 후 배포
- ✓ 최종 승인 절차

출처: KISA AI 보안 안내서 3.4.6

참고: KISA AI 보안 안내서(과학기술정보통신부·한국인터넷진흥원)



안전한 AI 구축 방안

KISA AI 보안 안내서 기반 AI 구축 4대 핵심 영역



인프라

- ✓ **폐쇄형/온프레미스**
내부망 환경에서 AI 서버 구축 **필수**
- ✓ **전용 VPC**
네트워크 격리 및 접근 제어
- ✓ **프록시 게이트웨이**
외부 AI 서비스 연결 제어
- ✓ **비공개 모델**
내부 AI 모델 배포

i 구축 우선순위

정부·공공기관은 폐쇄형 환경을 우선적으로 고려



데이터

- ✓ **RAG 적용** **적용**
검색 증강 생성 기술 활용
- ✓ **PII 마스킹**
개인정보 자동 마스킹·레다션
- ✓ **데이터 정합성**
학습 데이터 검증
- ✓ **민감정보 격리**
핵심 데이터 분리 저장

🛡️ 데이터 보호

DPIA(개인정보 영향평가) 필수 수행



보안

- ✓ **DLP 적용** **필수**
데이터 유출 방지 시스템
- ✓ **CASB 도입**
클라우드 보안 브로커
- ✓ **컨텐츠 필터링**
악성 콘텐츠 차단
- ✓ **비밀스캐닝**
민감정보 자동 탐지

👤 접근 제어

최소권한 원칙 적용



운영

- ✓ **레드팀 운영** **주기**
정기적 보안 테스트
- ✓ **가드레일**
AI 행동 제한 설정
- ✓ **로그 관리**
모든 활동 기록
- ✓ **감사 체계**
정기적 감사 수행

📊 모니터링

실시간 모니터링 및 알림



AI 바이브 코딩 보안 가이드

GitHub Copilot 공식 문서 기반

☰ 도구 화이트리스트 관리

필수

IDE 플러그인·에이전트 사전 검증/승인 후 사용

- 공인된 개발 도구만 사용 (VS Code, IntelliJ 등)
- 플러그인은 보안 검증 후 설치
- 정기적인 도구 업데이트 및 취약점 점검
- 승인된 AI 코딩 도구 목록 관리

🔒 GitHub Copilot 안전 설정

권장

트리거 권한 제한 (write access만)

- 자동 워크플로 금지 (PR은 항상 사람 리뷰)
- 전용 브랜치 (copilot/) 사용
- 인터넷 아웃바운드 제한
- 요청자는 자신의 PR 승인 불가

🔒 비밀 보호

필수

시크릿 스캐닝 및 하드코딩 금지

- 토큰·API키 분리 저장 (환경변수)
- GitHub Secret Scanning 활성화
- 커밋 전 민감정보 자동 검증
- Vault 등 보안 저장소 활용

🛡️ 코드 품질 관리

필수

SAST/DAST/CodeQL 로 의존성 검증

- SCA·SBOM**로 의존성 검증
- 라이선스 준수 확인 (GPL, MIT 등)
- 취약점 데이터베이스 연동
- 정적/동적 코드 분석

🔍 취약점 관리

주의

검증되지 않은 코드 사용 금지

- GitHub 코드/확장 기능 사전 검증
- 악성 의존성 체크
- 라이선스 이슈 확인
- 보안 패치 정기 업데이트

⚠️ 핵심 보안 원칙

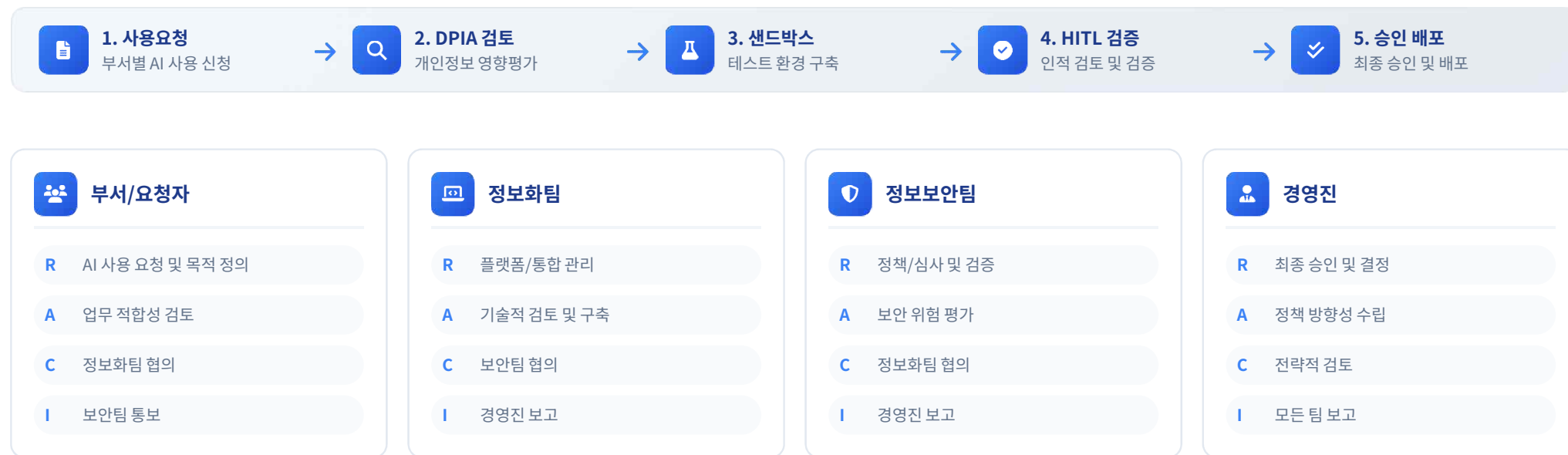
코드 리뷰는 필수이며, **자동화된 보안 검사**를 통해 AI 생성 코드의 취약점을 사전에 차단해야 합니다. **최소 권한 원칙**과 **HITL(Human-in-the-Loop)**을 준수하세요.

출처: GitHub Copilot 공식 문서



기관 적용 운영모델

| RACI 매트릭스와 승인 프로세스 시각화





기관 적용 운영모델

RACI 매트릭스와 승인 프로세스 시각화





실무 적용 Do/Don't 체크리스트

AI 활용 시 반드시 지켜야 할 행동 지침



해야 할 것 (Do)

안전한 AI 사용을 위한 필수 행동



승인된 내부 포털·모델만 사용

공식 승인된 AI 도구와 포털을 통해 접속하세요



PII는 가명처리 후 최소 공유

개인정보는 반드시 가명화하여 최소한만 공유



프롬프트·출력 저장 및 로그 관리

모든 AI 상호작용은 로그로 기록하여 추적 가능하게



출처·사실 검증 후 배포

AI 생성 내용은 반드시 사실 확인 후 배포



정기적인 보안 검토 및 업데이트

AI 도구와 정책을 정기적으로 검토하고 업데이트



최소 권한 원칙 준수

필요한 최소한의 권한만 부여하여 사용



하지 말아야 할 것 (Don't)

AI 사용 시 절대 금지되는 행동



외부 클라우드에 기관 자료 업로드 금지

개인 클라우드나 외부 저장소에 업무 자료 저장 금지



비밀키·토큰·시스템 설정 프롬프트에 붙여넣기

API 키나 시스템 설정을 AI에 입력하지 마세요



검증되지 않은 GitHub 기능·확장 설치

보안 검증되지 않은 코드나 확장 기능 사용 금지



민감정보 직접 AI에 입력

개인정보, 기밀, 민감한 데이터를 AI에 직접 입력 금지



자동 승인 없이 AI 생성 결과 배포

인적 검토 없이 AI 생성 결과를 배포하지 마세요



내부망/외부망 구분 없이 AI 사용

망분리 정책을 준수하여 AI 도구 사용



주요 용어 설명 (Glossary)

AI 보안 교육에 사용된 전문 용어 정리



AI 기본 용어

핵심 AI 기술 및 개념

- ✓ **LLM (Large Language Model)** AI
대규모 언어 모델 - ChatGPT와 같은 생성형 AI
- ✓ **RAG (Retrieval-Augmented Generation)** AI
검색 증강 생성 - 외부 데이터베이스를 검색하여 답변 생성
- ✓ **HITL (Human-in-the-Loop)** AI
사람이 개입하는 검토 : AI가 자동 결정하기 전 반드시 사람이 검토하고 승인
- ✓ **에이전트 AI** AI
자율적으로 목표를 설정하고 계획을 수립하며, 다양한 도구를 활용하여 복잡한 업무를 수행하는 지능형 시스템



보안 기준 및 프레임워크

AI 보안 규정 및 가이드라인

- ✓ **OWASP (Open Web Application Security Project)** 보안
웹 애플리케이션 보안 프로젝트 - LLM Top 10 위험 관리
- ✓ **DPIA (Data Protection Impact Assessment)** 보안
개인정보 영향평가 : 개인정보처리가 개인의 권리에 미치는 영향을 사전에 평가
- ✓ **PII (Personally Identifiable Information)** 보안
개인식별정보 - 개인을 식별할 수 있는 정보
- ✓ **GDPR (General Data Protection Regulation)** 보안
일반 데이터 보호 규정 - EU 개인정보 보호 법규



보안 검증 도구

AI 보안 테스트 및 분석 도구

- ✓ **SAST (Static Application Security Testing)** 도구
정적 애플리케이션 보안 테스트 - 소스 코드 분석
- ✓ **DAST (Dynamic Application Security Testing)** 도구
동적 애플리케이션 보안 테스트 - 실행 중 테스트
- ✓ **SCA (Software Composition Analysis)** 도구
소프트웨어 구성 분석 - 오픈소스 의존성 검증
- ✓ **SBOM (Software Bill of Materials)** 도구
소프트웨어 자재 명세서 - 사용된 모든 컴포넌트 목록



보안 기술

AI 보안 구현 기술

- ✓ **DLP (Data Loss Prevention)** 보안
데이터 유출 방지 시스템
- ✓ **CASB (Cloud Access Security Broker)** 보안
클라우드 접근 보안 중개자
- ✓ **레다션 (Redaction)** 보안
민감정보 삭제/가리기
- ✓ **암호화** 보안



운영 관리

AI 운영 및 거버넌스

- ✓ **RACI 매트릭스** 운영
역할과 책임 정의 도구
- ✓ **R (Responsible)** 운영
실행 책임자 - 작업을 실제로 수행하는 사람
- ✓ **A (Accountable)** 운영
최종 책임자 - 작업의 최종 승인 및 책임
- ✓ **C (Consulted)** 운영



추가 용어

기타 중요 용어

- ✓ **프롬프트 인젝션** AI
AI 모델에 악의적인 입력을 통해 원치 않는 출력 유도
- ✓ **환각** AI
Hallucination - AI가 사실이 아닌 정보를 사실처럼 생성
- ✓ **파인튜닝** AI
Fine-tuning - 기존 모델을 특정 데이터로 재학습
- ✓ **벡터 DB** AI



참고자료 및 부록

국내외 공공기관 AI 관련 주요 자료 및 링크



국제 기준

🔗 **OWASP LLM Top 10 v2 가이드**
LLM 애플리케이션 보안 10대 위험 (2025)
owasp.org

🔗 **NIST AI RMF 1.0 프레임워크**
AI 위험 관리 프레임워크
nist.gov

🔗 **ISO/IEC 42001 표준**
AI 관리 시스템 국제표준
iso.org



국내 공공기관 AI

🔗 **국정원 AI 위험사례집 2025.11**
AI 위험관리 전략 수립 기초자료
www.nis.go.kr

🔗 **KISA AI 보안 안내서 안내서**
과기정통부·한국인터넷진흥원
www.kisa.or.kr

🔗 **PIPC AI 안내서 2025.8**
생성형 AI 개인정보 처리 안내서
www.pipc.go.kr



AI 보안 및 안전

🔗 **NSA AISC 가이드 가이드**
AI 시스템 보안 강화 가이드
www.nsa.gov

🔗 **GitHub Copilot 보안 문서**
AI 코딩 어시스턴트 보안 가이드
docs.github.com

🔗 **OpenSSF 프로젝트**
오픈소스 보안 기초 프로젝트
openssf.org



해외 공공기관 AI

🔗 **UK AI Playbook 2025.2**
영국 정부 AI 활용 10대 원칙
www.gov.uk

🔗 **Singapore GovTech 공식**
싱가포르 정부 AI 활용 사례
www.tech.gov.sg

🔗 **US AI.gov 공식**
미국 연방정부 AI 전략
www.ai.gov



AI 교육 및 연구

🔗 **AI 교육 포털 교육**
공공기관 AI 역량 강화 교육
www.kisa.or.kr

🔗 **AI 연구 동향 리포트**
최신 AI 기술 동향 및 연구
www.spri.kr

🔗 **AI 윤리 가이드 가이드**
AI 윤리 및 책임 있는 AI 사용
www.mois.go.kr



AI 피해 사례

🔗 **AI 사고 사례집 사례**
AI 관련 사고 및 피해 사례
www.kimchang.com

🔗 **딥페이크 피해 사례**
딥페이크 관련 법적 대응
www.police.go.kr

🔗 **데이터 유출 사례 사례**
AI 서비스 데이터 유출 사례
www.kisa.or.kr